TÀI LIỆU ĐẶC TẢ NGHIỆP VỤ & KIỂM THỬ

CHU TRÌNH XÁC THỰC SINGPASS - KIẾN TRÚC PURE BFF (PATTERN 2)

MỤC LỤC

1. Tổng quan Nghiệp vụ & Kiến trúc Hệ thống (Executive Abstract & Topology)
2. Bảng Phân vai Dịch vụ & Thuật ngữ Cốt lõi (Service Registry & Glossary)
3. Đặc tả Chi tiết 4 Giai đoạn Xác thực & Dữ liệu Mẫu (Detailed Flows & Data Samples)
4. Sổ tay "Soi" Dữ liệu cho QA (QA DevTools & Inspection Cheatsheet)
5. Ma trận Kịch bản Kiểm thử (QA Test Matrix)
6. Tiêu chí Nghiệm thu Tính năng (Sign-off Acceptance Checklist)

---

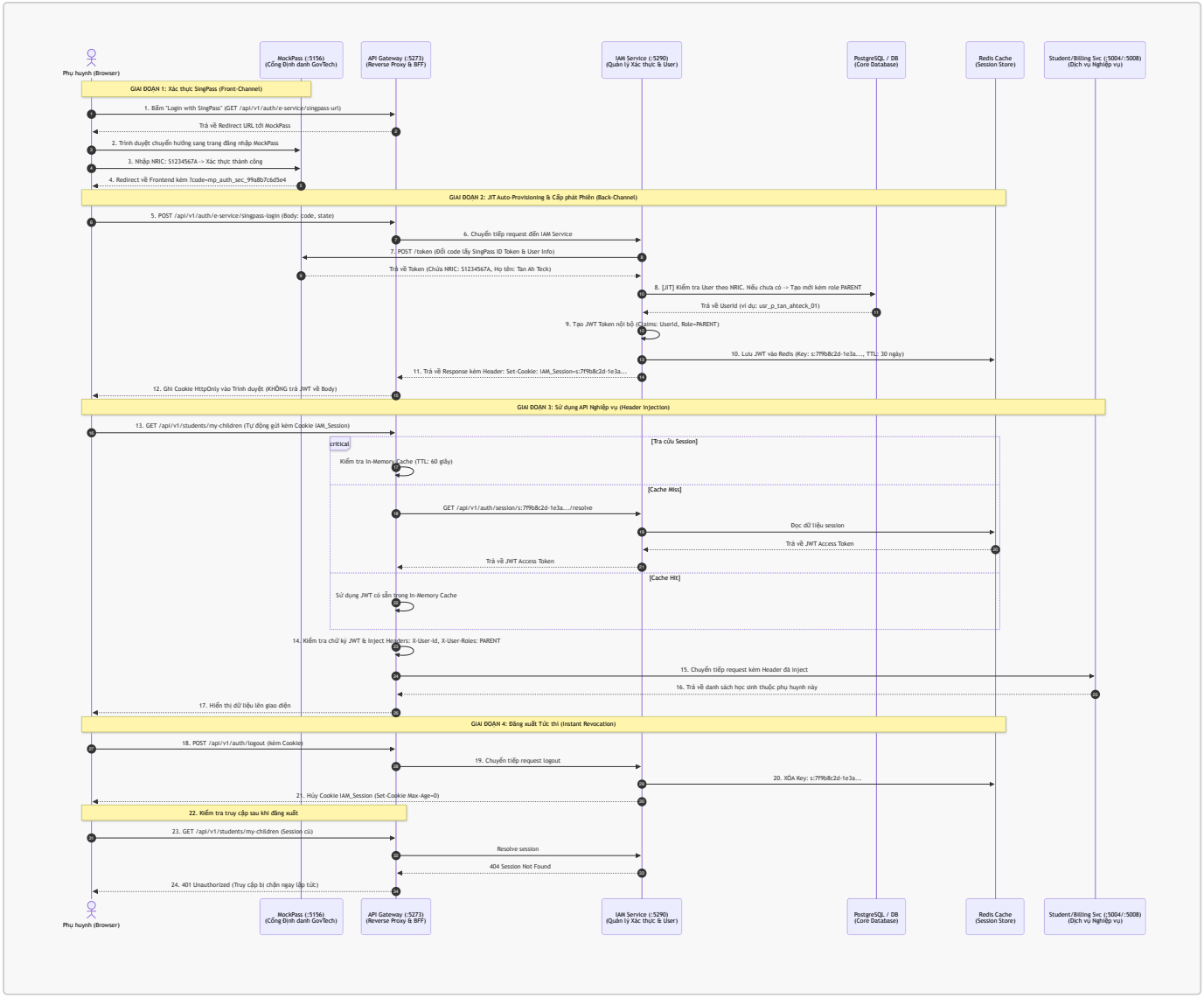
1. TỔNG QUAN NGHIỆP VỤ & KIẾN TRÚC HỆ THỐNG (EXECUTIVE ABSTRACT & TOPOLOGY)

1.1 Khái quát chu trình nghiệp vụ

Quy trình xác thực người dùng (Phụ huynh - `PARENT`) thông qua **SingPass** trên hệ thống áp dụng mô hình bảo mật **Pure BFF (Backend-For-Frontend)**. Bản chất của mô hình này được vận hành như sau:

- **Tuyệt đối không lưu Token ở Trình duyệt:** Trình duyệt người dùng (Frontend) **không** nhận và **không** lưu bất kỳ JWT Access Token hay Refresh Token nào trong `LocalStorage`, `SessionStorage` hay biến JavaScript toàn cục (loại trừ hoàn toàn nguy cơ bị đánh cắp Token khi xảy ra tấn công XSS).
- **Quản trị phiên qua Opaque Session Cookie:** Trình duyệt chỉ nhận và lưu trữ một chuỗi định danh phiên ngẫu nhiên, vô nghĩa với bên ngoài (gọi là `Opaque SessionId`, định dạng `s:<guid>`), được bảo vệ trong Cookie an toàn (`HttpOnly; Secure; SameSite=Lax`).
- **Két sắt Token tại Backend:** Toàn bộ dữ liệu nhạy cảm thực sự (Access Token, Refresh Token, Claims, Phân quyền) được cất giữ tập trung trong **Redis Cache**.
- **Đóng dấu Header tại Gateway:** Khi người dùng gửi yêu cầu sử dụng dịch vụ, **API Gateway (:5273)** đóng vai trò trạm kiểm soát: trích xuất Session ID từ Cookie, tra cứu Redis để lấy Token thật, xác thực chữ ký, rồi **"đóng dấu" (inject)** danh tính phụ huynh (`X-User-Id`, `X-User-Roles: PARENT`) vào Request Header trước khi chuyển tiếp sang các dịch vụ nghiệp vụ nội bộ (Student, Billing, School...).

1.2 Sơ đồ tuần tự nghiệp vụ (Mermaid Sequence Diagram)



2. BẢNG PHÂN VAI DỊCH VỤ & THUẬT NGỮ CỐT LÕI (SERVICE REGISTRY & GLOSSARY)

2.1 Bảng phân vai các dịch vụ trong hệ thống

Tên Dịch vụ	Địa chỉ (Port)	Vai trò Nghiệp vụ	Điểm QA cần chú ý kiểm tra
Frontend Web	`:3000` / Web	Cổng thông tin tương tác của Phụ huynh.	Đảm bảo không có Access Token trong `LocalStorage` hay `SessionStorage`.
API Gateway (YARP)	`:5273`	Cửa ngõ duy nhất, xác thực Cookie, quản lý In-Memory Cache (60s), đóng dấu Header `X-*`.	Nơi tiếp nhận toàn bộ request từ bên ngoài; trả mã lỗi `401 Unauthorized` nếu session sai/hết hạn.
MockPass	`:5156`	Giả lập Cổng định danh GovTech SingPass OIDC của Singapore.	Dùng để chọn NRIC test, sinh mã ủy quyền `authorization_code`.
IAM Service	`:5290`	Xử lý logic nghiệp vụ tài khoản, JIT provisioning, phát hành cặp token JWT, ghi/đọc Redis.	Quản lý bảng dữ liệu `Users`, `UserRoles` trong Database.
Redis Cache	`:6379`	Kho lưu trữ ánh xạ tập trung giữa `Opaque SessionId` và `JWT Token`.	Nơi kiểm tra sự tồn tại của Session Key và TTL.

Tên Dịch vụ	Địa chỉ (Port)	Vai trò Nghiệp vụ	Điểm QA cần chú ý kiểm tra
Student Service	`:5004`	Quản lý danh sách học sinh, hồ sơ con cái của phụ huynh.	Đọc Header `X-User-Id` để trả về đúng học sinh trực thuộc.
Billing Service	`:5008`	Quản lý học phí, hóa đơn của gia đình.	Đảm bảo phân quyền kiểm tra đúng vai trò `PARENT`.

2.2 Thuật ngữ cốt lõi cho QA

- **BFF (Backend-For-Frontend) Pattern 2:** Kiến trúc phân tách hoàn toàn tầng bảo mật: Frontend chỉ giao tiếp bằng Cookie an toàn, Backend tự quản lý và đối soát Token.
- **Opaque Session ID:** Chuỗi ký tự ngẫu nhiên duy nhất (dạng `s:<guid>`), không mang thông tin nhạy cảm. Bên ngoài không thể giải mã hay đọc được dữ liệu gì từ chuỗi này.
- **JIT (Just-In-Time) Provisioning:** Cơ chế tự động khởi tạo hồ sơ người dùng trong Database ngay tại thời điểm họ đăng nhập thành công lần đầu tiên qua SingPass mà không cần đăng ký tài khoản trước.
- **Header Injection:** Kỹ thuật Gateway tự động chèn thêm các HTTP Header nội bộ (`X-User-Id`, `X-User-Roles`) vào request trước khi đẩy xuống các Microservice phía sau.

---

3. ĐẶC TẢ CHI TIẾT 4 GIAI ĐOẠN XÁC THỰC & DỮ LIỆU MẪU (DETAILED FLOWS & DATA SAMPLES)

Giai đoạn 1: SingPass Handshake (Front-Channel)

1. Phụ huynh nhấn **"Log in with SingPass"** trên giao diện cổng dịch vụ.
2. Trình duyệt gửi request `GET /api/v1/auth/e-service/singpass-url` để lấy đường dẫn xác thực.
3. Người dùng được chuyển hướng đến cổng SingPass (*MockPass tại `:5156`*).
4. Phụ huynh nhập/chọn thông tin tài khoản mẫu:
   - **NRIC kiểm thử:** `S1234567A`
   - **Họ tên phụ huynh:** `Tan Ah Teck`
5. MockPass kiểm tra hợp lệ, sau đó chuyển hướng ngược về Frontend Callback URL kèm mã ủy quyền:
   - **Callback URL:** `https://portal.local/auth/callback?code=mp_auth_sec_99a8b7c6d5e4&state=xyz_state_protect`

Giai đoạn 2: JIT Auto-Provisioning & Cấp phát Phiên (Back-Channel)

1. Frontend trích xuất tham số `code` và gửi yêu cầu đăng nhập:
   - **Endpoint:** `POST https://gateway.portal.local:5273/api/v1/auth/e-service/singpass-login`
   - **Request Body mẫu:**

```
{
  "code": "mp_auth_sec_99a8b7c6d5e4",
  "state": "xyz_state_protect",
  "redirectUri": "https://portal.local/auth/callback"
}
```

2. Gateway chuyển tiếp yêu cầu đến **IAM Service (:5290)**.
3. IAM Service gọi ngầm sang MockPass để bóc tách thông tin danh tính từ SingPass ID Token:
   - Thông tin nhận diện: `NRIC = S1234567A`, `Name = Tan Ah Teck`.
4. **Cơ chế JIT (Just-In-Time) Provisioning kích hoạt:**
   - Hệ thống truy vấn Database. Do NRIC `S1234567A` chưa từng tồn tại:

- Tạo 1 bản ghi mới trong bảng `Users` với `Id = "usr_p_tan_ahteck_01"`.
- Gán quyền mặc định trong bảng `UserRoles` với `Role = "PARENT"`.

5. **Cấp phát phiên BFF:**
   - IAM phát hành cặp JWT: Access Token (thời hạn ngắn, e.g. 15 phút) và Refresh Token (thời hạn dài, e.g. 30 ngày).
   - Tạo một mã `SessionId` ngẫu nhiên: `s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e`.
   - Lưu toàn bộ dữ liệu này vào Redis.
6. **Bản ghi mẫu trong Redis:**
   - **Key:** `s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e`
   - **TTL:** `2,592,000` giây (30 ngày)
   - **Value (JSON lưu trữ):**

```
{
  "sessionId": "s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e",
  "userId": "usr_p_tan_ahteck_01",
  "nric": "S1234567A",
  "roles": ["PARENT"],
  "accessToken":
"eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJ1c3JfcF90YW5fYWh0ZWNrXzAxIiw
ibmFtZSI6IlRhbiBBaCBUZWNrIiwicm9sZXMiOlsicGFyZW50Il0sImV4cCI6MTcxOTU2MDAwMH0.
K2sX8...signature",
  "refreshToken": "rf_sec_8844aabbccdd112233",
  "createdAt": "2025-05-15T08:30:00Z"
}
```

7. **Response trả về cho Trình duyệt:**
   - **HTTP Status:** `200 OK`
   - **Header thiết lập Cookie:**

```
Set-Cookie: IAM_Session=s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e; Path=/;
HttpOnly; Secure; SameSite=Lax
```

   - **Response Body mẫu:**

```
{
  "success": true,
  "user": {
    "id": "usr_p_tan_ahteck_01",
    "name": "Tan Ah Teck",
    "role": "PARENT"
  }
}
```

(Lưu ý quan trọng cho QA: Body phản hồi tuyệt đối KHÔNG chứa accessToken/refreshToken).

Giai đoạn 3: Gọi API Nghiệp vụ & Header Injection

1. Phụ huynh truy cập màn hình xem thông tin con cái, trình duyệt gửi request:

```
GET /api/v1/students/my-children HTTP/1.1
Host: gateway.portal.local:5273
```

```
Cookie: IAM_Session=s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e
Accept: application/json
```

2. **Xử lý tại API Gateway (:5273):**
   - Gateway trích xuất `s:7f9b8c2d...` từ Cookie.
   - Tra cứu In-Memory Cache (TTL 60s). Nếu chưa có, Gateway gọi nội bộ `GET /api/v1/auth/session/{id}/resolve` sang IAM Service để lấy JWT từ Redis.
   - Gateway xác thực chữ ký JWT.
   - Gateway **"đóng dấu" (inject)** các thông tin nhận diện vào Header rồi forward tới **Student Service (:5004)**:

```
GET /api/v1/students/my-children HTTP/1.1
Host: internal-studentservice:5004
Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...
X-User-Id: usr_p_tan_ahteck_01
X-User-Roles: PARENT
X-Session-Id: s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e
```

3. **Student Service phản hồi:**
   - Student Service đọc header `X-User-Id: usr_p_tan_ahteck_01` và trả về danh sách con cái:

```
{
  "children": [
    {
      "studentId": "stu_2025_001",
      "fullName": "Tan Xiao Ming",
      "relationship": "Child",
      "class": "Primary 3-A"
    }
  ]
}
```

Giai đoạn 4: Đăng xuất Tức thì (Instant Revocation)

1. Phụ huynh nhấn nút **"Đăng xuất" (Logout)** trên giao diện.
2. Frontend gửi request:

```
POST /api/v1/auth/logout HTTP/1.1
Host: gateway.portal.local:5273
Cookie: IAM_Session=s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e
```

3. IAM Service nhận request và **xóa ngay lập tức key `s:7f9b8c2d-1e3a-4b5c-9d8e-0f1a2b3c4d5e` khỏi Redis**.
4. Response trả về chỉ thị xóa Cookie trên trình duyệt:

```
Set-Cookie: IAM_Session=; Path=/; Expires=Thu, 01 Jan 1970 00:00:00 GMT; Max-Age=0
```

5. **Kiểm tra tính thu hồi tức thì:** Bất kỳ request nào sau đó cố tình dùng lại giá trị Cookie cũ `s:7f9b8c2d...` sẽ bị Gateway từ chối ngay lập tức bằng mã lỗi **`401 Unauthorized`** (do Redis không còn bản ghi để resolve).

---

4. SỔ TAY "SOI" DỮ LIỆU CHO QA (QA DEVTOOLS & INSPECTION CHEATSHEET)

Khi tiến hành kiểm thử hoặc phân tích nguyên nhân lỗi (troubleshooting), QA kiểm tra dữ liệu tại các vị trí sau:

```
[Trình duyệt F12]                    [Hạ tầng Gateway]              [Cơ sở dữ liệu
Redis]
   │                                    │                              │
   ├── Tab Application: Cookies         ├── Console Log YARP           └── CLI: redis-
cli
   │   (IAM_Session = s:<guid>)         │   (Check resolve 60s cache)      ├── KEYS s:*
   └── Tab Network: Response Payload    └── Header Injection               └── TTL s:<guid>
       (Chỉ có User info, KHÔNG JWT)        (X-User-Id, X-User-Roles)
```

Bảng đối soát chi tiết cho QA:

Mục tiêu kiểm tra	Vị trí thao tác	Dấu hiệu ĐẠT (Pass)	Dấu hiệu LỖI (Bug)
Cấu hình Cookie BFF	DevTools -> **Application** -> Storage -> Cookies	Có Cookie tên `IAM_Session`. Giá trị có tiền tố `s:` (ví dụ `s:7f9b...`). Cột **HttpOnly** có dấu tích. Cột **SameSite** hiển thị `Lax`.	Thiếu cờ `HttpOnly` hoặc `SameSite`; giá trị cookie rỗng; hoặc tên cookie bị sai.
Bảo mật Body Response	DevTools -> **Network** -> request `singpass-login`	Response Body dạng JSON chỉ chứa metadata người dùng (`id`, `name`, `role: PARENT`).	Response Body chứa chuỗi Token dạng `accessToken: eyJ...` hoặc `refreshToken`.
Bản ghi phiên Redis	Terminal máy chủ Redis: `redis-cli`	Chạy lệnh `KEYS s:*` -> tìm thấy session. Chạy lệnh `TTL s:<guid>` -> trả về số nguyên dương (`> 0`).	Đăng nhập thành công nhưng không có key nào dạng `s:*` trên Redis.
In-Memory Cache (Gateway)	Console Log của API Gateway	Lần gọi API thứ nhất: Xuất hiện log `Resolving session from IAM`. Các lần gọi tiếp theo trong 60 giây: Không có log resolve sang IAM.	Mỗi request gọi từ trình duyệt đều kích hoạt 1 request `resolve` sang IAM (Cache không hoạt động).
Thu hồi phiên khi Logout	Redis CLI & Postman	Sau khi bấm Logout trên Web: 1. Lệnh `EXISTS s:<guid>` trên Redis trả về `0`. 2. Dùng Postman gửi lại Cookie cũ -> Gateway trả về `401 Unauthorized`.	Sau khi bấm Logout, bản ghi Redis vẫn còn; hoặc dùng Cookie cũ vẫn lấy được dữ liệu `200 OK`.

5. MA TRẬN KỊCH BẢN KIỂM THỬ (QA TEST MATRIX)

5.1 Nhóm Kịch bản Luồng chuẩn (Happy Path Scenarios)

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
HP-01	Đăng nhập lần đầu bằng SingPass (JIT Provisioning)	NRIC mới: `S8899001A` (chưa có trong CSDL).	1. Mở Cổng thông tin, chọn SingPass. 2. Nhập NRIC `S8899001A` trên MockPass. 3. Xác nhận chuyển hướng về hệ thống.	- Database tự tạo 1 bản ghi trong bảng `Users`. - Bảng `UserRoles` được gán vai trò `PARENT`. - Trình duyệt nhận Cookie `IAM_Session`. - Người dùng được điều hướng vào Dashboard phụ huynh.
HP-02	Đăng nhập bằng tài khoản Phụ huynh hiện hữu	NRIC: `S1234567A` (đã có sẵn trong CSDL).	1. Đăng nhập qua MockPass với NRIC `S1234567A`.	- Database không tạo thêm dòng mới. - Cột `LastLoginAt` của user được cập nhật thời gian hiện tại. - Phiên mới được lưu vào Redis thành công.
HP-03	Gọi API nghiệp vụ liên tiếp (Kiểm tra Cache 60s)	Cookie phiên đăng nhập hợp lệ.	1. Gọi `GET /api/v1/students/my-children` lần 1. 2. Gọi lại API này 3 lần liên tiếp trong vòng 10 giây.	- Cả 4 lần đều trả về HTTP `200 OK` kèm dữ liệu học sinh. - Log Gateway xác nhận: Chỉ có lần 1 gọi sang IAM, 3 lần sau lấy trực tiếp từ bộ nhớ đệm RAM.

5.2 Nhóm Kịch bản Bảo mật & Ngoại lệ (Security & Negative Scenarios)

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
SEC-01	Kiểm tra miễn nhiễm đánh cắp Cookie qua XSS	Đoạn mã Script kiểm tra: `console.log(document.cookie)`	1. Đăng nhập thành công vào trang. 2. Bật Console của trình duyệt (F12). 3. Chạy lệnh `console.log(document.cookie)`.	- Chuỗi cookie in ra màn hình **không xuất hiện** `IAM_Session` (nhờ cờ bảo vệ `HttpOnly`).
SEC-02	Giả mạo Cookie Session ID	Cookie giả mạo: `IAM_Session=s:00000000-0000-0000-0000-fakeguid1234`	1. Mở Application -> Cookies, thay đổi giá trị của `IAM_Session` thành chuỗi giả mạo. 2. Tải lại trang (F5).	- Gateway tra cứu Redis thất bại. - Gateway trả về mã HTTP `401 Unauthorized`. - Giao diện Frontend

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
				chuyển hướng về trang Login.
SEC-03	Sử dụng lại Authorization Code đã hết hạn / đã dùng	Mã `code` đã trao đổi thành công từ kịch bản trước.	1. Mở Postman, gọi trực tiếp `POST /api/v1/auth/e-service/singpass-login` với `code` cũ.	- IAM Service trả về mã phản hồi `400 Bad Request` hoặc `401 Unauthorized`. - Không có session mới nào được sinh thêm trên Redis.
SEC-04	Kiểm thử Đăng xuất tức thì (Instant Revocation)	Tài khoản phụ huynh đang hoạt động bình thường.	1. Nhấn nút "Đăng xuất" trên Web. 2. Dùng Postman gửi request nghiệp vụ kèm Cookie của phiên vừa logout.	- Request bị từ chối ngay lập tức với mã HTTP `401 Unauthorized`. - Bản ghi session tương ứng trên Redis đã bị xóa sạch.
SEC-05	Hỗ trợ lập trình viên (Swagger / Postman dùng Bearer Token)	Header: `Authorization: Bearer <valid_jwt>` (Không kèm Cookie).	1. Dùng Postman gọi trực tiếp một API qua Gateway kèm Header Authorization chứa JWT hợp lệ.	- Gateway nhận diện được cơ chế Bearer. - Chữ ký JWT hợp lệ và trả về kết quả `200 OK` (Gateway hỗ trợ song song cả 2 cơ chế).

6. TIÊU CHÍ NGHIỆM THU TÍNH NĂNG (SIGN-OFF ACCEPTANCE CHECKLIST)

Trước khi xác nhận hoàn thành kiểm thử (Sign-off) luồng xác thực SingPass BFF, QA cần kiểm tra và đánh dấu đầy đủ các tiêu chuẩn sau:

- ☐ **Đúng Vai trò Nghiệp vụ:** Tài khoản đăng nhập qua SingPass luôn được gán đúng vai trò `PARENT` trong Database.
- ☐ **Bảo vệ Cookie Tuyệt đối:** Cookie `IAM_Session` trên trình duyệt có đầy đủ 3 cờ: `HttpOnly = true`, `Secure = true`, `SameSite = Lax`.
- ☐ **Không Rò rỉ Token (Zero Token Leakage):** Tuyệt đối không có JWT Access Token hoặc Refresh Token nào xuất hiện trong `LocalStorage`, `SessionStorage` hay Response Body của các API công khai.
- ☐ **Chuẩn hóa Header Nội bộ:** Các dịch vụ phía sau (Student, School, Billing) nhận đầy đủ và chính xác các Header: `X-User-Id`, `X-User-Roles: PARENT`, `X-Session-Id` từ Gateway.
- ☐ **Hiệu năng & Thu hồi Phiên:** Cơ chế In-Memory Cache 60 giây tại Gateway hoạt động ổn định; thao tác Logout hủy bỏ phiên làm việc ngay lập tức trên Redis.